

MOTS DE PASSE

Windows Server 2022 & Debian 12

Programme

01 Les critères d'une politique robuste

02 configurer une politique de mot de passe

03 Comparatif & bonnes pratiques

04 TP : sécuriser les comptes ARCADIA

05 Gestionnaires de mots de passe



POURQUOI UNE POLITIQUE ?

Pourquoi les mots de passe sont-ils encore attaqués ?



Le mot de passe reste, de très loin, le facteur d'authentification le plus répandu, et la tendance humaine à privilégier la mémorisation facile sur la robustesse en fait une cible de choix.

Les types d'attaques de mots de passe

Dictionnaire

L'attaquant teste une liste de mots de passe courants, de mots du dictionnaire ou de combinaisons fréquemment utilisées.

Force brute

Tester systématiquement toutes les combinaisons de caractères possibles, une à une.

Credential Stuffing

Les attaquants utilisent des identifiants (adresse e-mail et mot de passe) volés lors d'une fuite de données pour tenter de se connecter à d'autres services.

Password Spraying

Au lieu de tester de nombreux mots de passe sur un seul compte, l'attaquant essaie quelques mots de passe très courants sur un grand nombre de comptes

Man-in-the-Middle / Keylogger

Attaque par interception: Le mot de passe est capturé lors de sa saisie ou de sa transmission.

Attaque par ingénierie sociale

L'attaquant manipule la victime pour qu'elle révèle volontairement son mot de passe.

Les trois piliers d'une politique robuste

Ce qu'il faut exiger, quel que soit le système.



VERROUILLAGE & EXPIRATION

Bloquer le compte après plusieurs échecs, renouveler le mot de passe régulièrement.



LONGUEUR & DIVERSITÉ

12 caractères minimum, mêlant majuscules, minuscules, chiffres et symboles.



HISTORIQUE & UNICITÉ

Interdire la réutilisation des derniers mots de passe, et entre plusieurs comptes.

MOT DE PASSE FAIBLE

- « azerty123 » : cassé en un instant par un simple dictionnaire.
- Réutilisé sur plusieurs comptes personnels et professionnels.
- Jamais renouvelé, même après plusieurs années d'usage.

MOT DE PASSE ROBUSTE

- 16 caractères mêlant majuscules, minuscules, chiffres et symboles et absence de mots du dictionnaire ou d'informations personnelles
- Unique pour chaque compte, généré et stocké dans un gestionnaire de mots de passe.
- Renouvelé tous les 90 jours grâce à une politique appliquée sur Windows / Linux ...



DÉMO — WINDOWS SERVER 2022

DÉMONSTRATION WINDOWS · ÉTAPE 1/5

WINDOWS

Créer un compte de test

Sur SRV-AD01, avant de modifier la stratégie, on prépare un compte pour en vérifier l'effet.

```
New-LocalUser "m.khaled" -Description "Admin junior"
```

ÉTAPE 2/5

Ouvrir la stratégie de sécurité locale

Exécuter → secpol.msc, puis naviguer jusqu'à la stratégie de mot de passe.

```
secpol.msc

Stratégies de comptes
  > Stratégie de mot de passe
  > Stratégie de verrouillage du compte
```

WINDOWS

Configurer la stratégie de mot de passe

Régler les exigences dans le panneau Stratégie de mot de passe.

```
# Stratégies de comptes > Stratégie de mot de passe
Longueur minimale ................. 12
Complexité ........................ Activée
Durée de vie maximale ............. 90 jours
Historique conservé ............... 5 derniers

# Équivalent en ligne de commande
net accounts /minpwlen:12 /maxpwage:90 /uniquepw:5
```

Le mot de passe « Password1 » du compte initial ne respecte plus ces règles.

DÉMONSTRATION WINDOWS · ÉTAPE 4/5

WINDOWS

Configurer la stratégie de verrouillage

Toujours dans secpol.msc, régler le verrouillage du compte.

```
# Stratégies de comptes > Verrouillage du compte
Seuil de verrouillage ..............  5 tentatives
Durée de verrouillage ..............  15 minutes
Réinitialiser le compteur après ....  15 minutes
```

DÉMONSTRATION WINDOWS · ÉTAPE 5/5

Tester la stratégie

Vérifier que Windows applique bien les nouvelles règles.

```
# Un mot de passe faible est refusé par Windows :
# "Ne respecte pas les exigences de longueur,
#  de complexité ou d’historique."
 Set-LocalUser "m.khaled" -Password (Read-Host -AsSecureString)
# Read-Host : Cette fonction demande à l'utilisateur de saisir du texte au clavier.
# -AsSecureString : Cette option est cruciale car elle masque les caractères que vous tapez
# Vérifier la stratégie appliquée
net accounts
```



DÉMO — DEBIAN 12

DÉMONSTRATION DEBIAN · ÉTAPE 1/4

DEBIAN

Créer un utilisateur et installer pam_pwquality

Sur SRV-APP01, on prépare le compte de test et le module de contrôle.

```
sudo adduser m.khaled
sudo apt install libpam-pwquality
```

DEBIAN

Configurer /etc/security/pwquality.conf

Ce fichier définit les exigences appliquées à chaque nouveau mot de passe.

```
difok = 1             # au moins 1 caractère soit différent de l’ancien mot de passe
minlen = 12           # le mot de passe doit contenir au moins 12 caractères
dcredit = -1          # au moins 1 chiffre
ucredit = -1          # au moins 1 majuscule
lcredit = -1          # au moins 1 minuscule
ocredit = -1          # au moins 1 caractère spécial
maxrepeat = 1         # Limite le nombre de caractères identiques consécutifs
maxclassrepeat = 1    # Limite le nombre de caractères consécutifs appartenant à la même catégorie
gecoscheck =1         # Vérifie que le mot de passe ne contient pas des informations personnelles provenant de /etc/passwd
dictcheck = 1         # Recherche le mot de passe dans un dictionnaire Cracklib
usercheck = 1         # Empêche d’utiliser le nom d’utilisateur dans le mot de passe
usersubstr = 3        # Controle egalement les sous-chaînes du nom d’utilisateur
enforching = 1        # un mot de passe ne respectant pas les règles est refusé
retry = 3             # Nombre maximal de tentatives pour saisir un mot de passe valide
```

DEBIAN

Vérifier /etc/pam.d/common-password

S'assurer que le module pam_pwquality est bien appelé avant l'enregistrement.

```
# Ligne attendue dans /etc/pam.d/common-password :
password requisite pam_pwquality.so retry=3

# Si la ligne est absente, l'ajouter juste avant :
# password [success=1 default=ignore] pam_unix.so
```

DEBIAN

Configurer l'expiration du mot de passe

chage pilote un compte ; /etc/login.defs fixe les valeurs par défaut.

```
# Valeurs par défaut pour les nouveaux comptes
# /etc/login.defs
PASS_MAX_DAYS   90  # Durée maximale en jours de validité du mot de passe
PASS_MIN_DAYS   1   # Durée minimale en jours entre deux changements de mot de passe
PASS_WARN_AGE   7   # Nombre de jours avant l'expiration pour l'avertissement
```



Une politique non testée n'est qu'une intention.

Avez-vous des questions ?

